

Vertrag über die Auftragsverarbeitung

gemäß Art. 28 DSGVO

(im Folgenden „AVV“)

Zwischen

Firma / Name des Auftraggebers:

Straße, Hausnummer:

PLZ, Ort: _____

Vertretungsberechtigte Person:

E-Mail: _____

– nachfolgend „Verantwortlicher“ genannt –

und

FotoLutz Complex GmbH

Metzer Straße 158, 66117 Saarbrücken

vertreten durch den Geschäftsführer Markus Lutz

Amtsgericht Saarbrücken, HRB 14172

E-Mail: office@fotolutz.com

– nachfolgend „Auftragsverarbeiter“ genannt –

– gemeinsam auch die „Parteien“ –

Präambel

Die Parteien haben einen Hauptvertrag über die Vermietung und/oder den Betrieb einer Fotobox bzw. eines mobilen Fotoprintsystems sowie die Bereitstellung einer digitalen Event-Galerie geschlossen (im Folgenden „Hauptvertrag“). Im Rahmen der Durchführung dieses Hauptvertrages verarbeitet der Auftragsverarbeiter personenbezogene Daten im Auftrag des Verantwortlichen.

Die Parteien schließen den vorliegenden AVV, um den Anforderungen der Datenschutz-Grundverordnung (DSGVO), insbesondere des Art. 28 DSGVO, zu entsprechen.

§ 1 Gegenstand und Dauer der Verarbeitung

1.1 Gegenstand

Gegenstand der Verarbeitung ist die Erfassung, Speicherung und Bereitstellung von Foto- und Videoaufnahmen sowie damit verbundener Daten (z. B. Foto-PIN, E-Mail-Adressen zum Versand der Bilder) im Rahmen der vom Verantwortlichen beauftragten Veranstaltung.

1.2 Veranstaltungsdaten

Bezeichnung der Veranstaltung:

Veranstaltungsort: _____

Datum / Zeitraum der Veranstaltung:

1.3 Dauer der Verarbeitung

Die Verarbeitung beginnt mit der Bereitstellung der Fotobox / des Fotosystems am vereinbarten Veranstaltungsort und endet mit der vollständigen Löschung der erhobenen Daten, spätestens jedoch 30 Tage nach Beendigung der Veranstaltung, sofern keine abweichende Vereinbarung getroffen wurde.

§ 2 Art und Zweck der Verarbeitung

2.1 Art der Verarbeitung

Die Verarbeitung umfasst insbesondere:

- Erfassung von Foto- und ggf. Videoaufnahmen durch die Fotobox
- Lokale Zwischenspeicherung auf der Fotobox-Hardware
- Übertragung in eine passwort-/PIN-geschützte Event-Galerie
- Bereitstellung zum Download durch berechtigte Personen
- Sofern vereinbart: Sofortdruck am Veranstaltungsort
- Sofern vereinbart: Versand per E-Mail oder QR-Code
- Automatisierte Löschung nach Ablauf der Speicherfrist

2.2 Zweck

Zweck der Verarbeitung ist die Erbringung der vertraglich vereinbarten Fotobox-Dienstleistung gegenüber dem Verantwortlichen und seinen Gästen.

§ 3 Art der personenbezogenen Daten und Kategorien betroffener Personen

3.1 Art der Daten

Gegenstand der Verarbeitung sind insbesondere folgende Datenkategorien:

- Bilddaten (Fotografien von Personen)
- ggf. Videoaufnahmen / GIFs / Boomerang-Aufnahmen
- technische Daten (Zeitstempel, Foto-PIN, IP-Adresse beim Download)
- sofern aktiv eingegeben: E-Mail-Adressen oder Mobilfunknummern zum Versand

3.2 Kategorien betroffener Personen

- Gäste und Besucher der Veranstaltung
- Mitarbeitende des Verantwortlichen, sofern an der Veranstaltung teilnehmend
- Dritte, die sich freiwillig fotografieren lassen

§ 4 Pflichten des Auftragsverarbeiters

4.1 Weisungsgebundenheit

Der Auftragsverarbeiter verarbeitet personenbezogene Daten ausschließlich auf dokumentierte Weisung des Verantwortlichen, sofern er nicht durch das Recht der Europäischen Union oder eines Mitgliedstaats zur Verarbeitung verpflichtet ist. In einem solchen Fall teilt der Auftragsverarbeiter dem Verantwortlichen die rechtlichen Anforderungen vor der Verarbeitung mit, sofern das Recht dies nicht aus wichtigen Gründen des öffentlichen Interesses verbietet.

Der Hauptvertrag und dieser AVV gelten als dokumentierte Weisung des Verantwortlichen. Mündliche Weisungen sind unverzüglich in Textform (E-Mail genügt) zu bestätigen.

4.2 Vertraulichkeit

Der Auftragsverarbeiter stellt sicher, dass die zur Verarbeitung der personenbezogenen Daten befugten Personen sich zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.

4.3 Technisch-organisatorische Maßnahmen (TOM)

Der Auftragsverarbeiter ergreift alle erforderlichen Maßnahmen gemäß Art. 32 DSGVO zur Sicherheit der Verarbeitung. Die konkreten Maßnahmen sind in Anlage 1 zu diesem AVV beschrieben.

4.4 Unterstützung des Verantwortlichen

Der Auftragsverarbeiter unterstützt den Verantwortlichen bei der Erfüllung seiner Pflichten gemäß Art. 32 bis 36 DSGVO (Sicherheit, Meldepflichten, Datenschutz-Folgenabschätzung) sowie bei der Beantwortung von Anträgen betroffener Personen (Art. 12 bis 23 DSGVO).

4.5 Meldepflicht bei Datenschutzverletzungen

Der Auftragsverarbeiter meldet dem Verantwortlichen jede ihm bekannt gewordene Verletzung des Schutzes personenbezogener Daten unverzüglich, spätestens jedoch innerhalb von 48 Stunden nach Bekanntwerden. Die Meldung enthält mindestens die in Art. 33 Abs. 3 DSGVO genannten Informationen.

4.6 Löschung und Rückgabe

Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht der Auftragsverarbeiter alle personenbezogenen Daten nach Wahl des Verantwortlichen oder gibt sie zurück, sofern nicht nach Unionsrecht oder Recht der Mitgliedstaaten eine Verpflichtung zur Speicherung besteht. Eine Löschbestätigung wird auf Verlangen ausgestellt.

4.7 Datenschutzbeauftragter

Der Auftragsverarbeiter hat *[einen Datenschutzbeauftragten benannt / keinen Datenschutzbeauftragten benannt, da nach § 38 BDSG keine Bestellpflicht besteht]*.

Kontakt Datenschutz (E-Mail):

§ 5 Pflichten des Verantwortlichen

Der Verantwortliche ist für die Rechtmäßigkeit der Verarbeitung sowie für die Wahrung der Rechte der betroffenen Personen allein verantwortlich. Er sichert insbesondere zu:

- (1) die abgebildeten Personen über die Datenverarbeitung zu informieren (z. B. durch Aushang am Aufstellort der Fotobox)
- (2) erforderliche Einwilligungen nach Art. 6 Abs. 1 lit. a DSGVO und ggf. §§ 22, 23 KUG einzuholen, soweit die Verarbeitung nicht auf eine andere Rechtsgrundlage gestützt werden kann
- (3) dem Auftragsverarbeiter rechtzeitig alle für die Vertragsdurchführung erforderlichen Informationen zur Verfügung zu stellen
- (4) im Falle von Auskunfts-, Löschungs- oder Widerspruchersuchen betroffener Personen federführend zu reagieren und den Auftragsverarbeiter ggf. zu beauftragen

§ 6 Unterauftragsverarbeiter

6.1 Genehmigte Unterauftragsverarbeiter

Der Verantwortliche erteilt seine allgemeine Genehmigung zur Hinzuziehung der nachfolgend genannten Unterauftragsverarbeiter:

Unterauftragsverarbeiter	Anschrift / Sitz	Zweck	Drittland
ALL-INKL.COM – Neue Medien Münnich	Hauptstraße 68, 02742 Friedersdorf, Deutschland	Webhosting der Event-Galerie	Nein (DE)
Cloudflare, Inc.	101 Townsend Street, San Francisco, CA 94107, USA	CDN, DDoS-Schutz, DNS	USA (SCC + DPF)
Formspree, Inc.	1007 N Orange St. 4th Floor, Wilmington, DE 19801, USA	Kontaktformular- Übermittlung	USA (SCC)

6.2 Änderungen

Eine Änderung oder Hinzuziehung weiterer Unterauftragsverarbeiter wird dem Verantwortlichen mit angemessener Vorlaufzeit (mindestens 30 Tage) in Textform mitgeteilt. Der Verantwortliche kann innerhalb von 14 Tagen aus wichtigem datenschutzrechtlichem Grund Einspruch erheben.

6.3 Vertragliche Sicherstellung

Der Auftragsverarbeiter schließt mit jedem Unterauftragsverarbeiter einen Vertrag, der diesem im Wesentlichen dieselben Datenschutzpflichten auferlegt, wie sie in diesem AVV festgelegt sind.

§ 7 Kontrollrechte des Verantwortlichen

Der Verantwortliche hat das Recht, sich von der Einhaltung der vertraglich getroffenen technischen und organisatorischen Maßnahmen zu überzeugen. Der Auftragsverarbeiter stellt dem Verantwortlichen hierzu auf Anfrage alle erforderlichen Informationen zur Verfügung.

Vor-Ort-Kontrollen sind mit angemessener Vorlaufzeit (mindestens 14 Tage) während der üblichen Geschäftszeiten anzukündigen und so durchzuführen, dass der Geschäftsbetrieb nicht unangemessen beeinträchtigt wird. Der Auftragsverarbeiter kann anstelle einer Vor-Ort-Kontrolle die Vorlage geeigneter Zertifikate oder Prüfberichte vorlegen.

§ 8 Drittlandstransfer

Eine Übermittlung personenbezogener Daten in Drittländer außerhalb des EWR erfolgt nur, wenn die in Art. 44 ff. DSGVO genannten Voraussetzungen erfüllt sind. Bei den in § 6 genannten US-Anbietern wird die Übermittlung auf die EU-Standardvertragsklauseln (SCC) sowie ggf. das EU-US Data Privacy Framework (DPF) gestützt.

§ 9 Haftung

Die Haftung der Parteien richtet sich nach Art. 82 DSGVO sowie den ergänzenden Bestimmungen des Hauptvertrages. Im Verhältnis der Parteien zueinander haftet jede Partei für Schäden, die durch ihre eigene Pflichtverletzung verursacht wurden.

§ 10 Vertragsdauer und Kündigung

Dieser AVV tritt mit Unterzeichnung in Kraft und gilt für die Laufzeit des Hauptvertrages. Eine außerordentliche Kündigung aus wichtigem Grund, insbesondere bei schwerwiegenden Verstößen gegen datenschutzrechtliche Bestimmungen, bleibt unberührt.

§ 11 Schlussbestimmungen

Änderungen und Ergänzungen dieses AVV bedürfen der Textform. Sollten einzelne Bestimmungen unwirksam sein, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt. Es gilt deutsches Recht. Gerichtsstand ist – soweit zulässig – Saarbrücken.

Unterschriften

Für den Verantwortlichen	Für den Auftragsverarbeiter
Ort, Datum	Ort, Datum
Unterschrift, Name in Druckbuchstaben	Markus Lutz, Geschäftsführer FotoLutz Complex GmbH

Anlage 1: Technische und organisatorische Maßnahmen (TOM)

Diese Anlage beschreibt die vom Auftragsverarbeiter getroffenen technischen und organisatorischen Maßnahmen gemäß Art. 32 DSGVO.

1. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

Zutrittskontrolle: Verhinderung des unbefugten Zutritts zu Datenverarbeitungsanlagen:

- Geschäftsräume in Saarbrücken sind durch Sicherheitsschlösser gesichert
- Schlüsselregelung und Zutritt nur für autorisiertes Personal
- Fotobox-Hardware wird während Veranstaltungen durch Personal beaufsichtigt oder beim Selbstbedienungs-Setup an einem kontrollierten Ort aufgestellt

Zugangskontrolle: Verhinderung der unbefugten Nutzung von Systemen:

- Passwortgeschützte Arbeitsplätze
- Komplexe Passwörter nach aktuellem Stand der Technik
- Fotobox-Software ist durch Administrator-Passwörter geschützt
- Event-Galerie nur per individuellem Foto-PIN oder Passwort zugänglich

Zugriffskontrolle: Berechtigungskonzept und Beschränkung auf das Notwendige:

- Rollen- und Berechtigungskonzept im WordPress-Backend
- Trennung von Administrator-, Bearbeiter- und Lese-Rechten
- Protokollierung von Zugriffen auf Event-Galerien

Trennungskontrolle: Getrennte Verarbeitung verschiedener Auftraggeber:

- Jede Veranstaltung erhält eine eigene, isolierte Galerie mit eigenem PIN
- Kein veranstaltungsübergreifender Datenaustausch

Pseudonymisierung / Verschlüsselung:

- SSL-/TLS-Verschlüsselung der Datenübertragung (HTTPS)
- Festplattenverschlüsselung auf Arbeitsplatzgeräten
- Backup-Datenträger werden verschlüsselt aufbewahrt

2. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

Weitergabekontrolle:

- Verschlüsselte Übertragung aller Bilddaten von der Fotobox zur Cloud-Galerie
- Keine Datenweitergabe an Dritte ohne ausdrückliche Weisung
- Verwendung von Cloudflare als verschlüsselter Proxy

Eingabekontrolle:

- Protokollierung von Änderungen an Galerie-Einstellungen
- Backup-Strategie ermöglicht Wiederherstellung im Fehlerfall

3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

- Regelmäßige Backups beim Hosting-Anbieter ALL-INKL
- Cloudflare als DDoS-Schutz und Performance-Optimierung
- Redundante Internetanbindung in den Geschäftsräumen
- Hardware-Backup-Systeme für Fotoboxen werden bei Bedarf vorgehalten
- Notfallkonzept zur Wiederherstellung von Datenbeständen

4. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

- Jährliche Überprüfung der eingesetzten Dienstleister und ihrer Datenschutzkonformität
- Schulung der Mitarbeitenden zum Thema Datenschutz
- Datenschutz-Folgeabschätzung bei Einführung neuer Verarbeitungstätigkeiten
- Dokumentation aller Verarbeitungstätigkeiten im Verzeichnis nach Art. 30 DSGVO

5. Auftragskontrolle

- Schriftliche Weisungen durch den Verantwortlichen werden dokumentiert
 - Unterauftragsverarbeiter werden vor Beauftragung sorgfältig ausgewählt
 - Mit allen Unterauftragsverarbeitern bestehen entsprechende AVV
 - Regelmäßige Überprüfung der Unterauftragsverarbeiter
-